ĐẠI HỌC KINH TẾ QUỐC DÂN
KHOA CÔNG NGHỆ THÔNG TIN

Bài giảng

AN TOÀN VÀ BẢO MẬT THÔNG TIN

Chương 1: TỔNG QUAN VỀ AN TOÀN VÀ BẢO MẬT THÔNG TIN

ThS. Nguyễn Quốc Thái

MỤC TIÊU CHƯƠNG

- 📚 **Kiến thức:**
  - Trình bày được các khái niệm cơ bản về an toàn và bảo mật thông tin
  - Phân tích được các mối đe dọa và rủi ro trong hệ thống thông tin
  - Nêu được các nguyên tắc và mục tiêu chung của ATBMTT
- 🛠️ **Kỹ năng:**
  - Phân loại và đánh giá các dạng tấn công an toàn thông tin
  - Các giải pháp bảo vệ phù hợp cho từng loại mối đe dọa

NỘI DUNG CHƯƠNG

- 1. Giới thiệu chung
- 2. Một số dạng tấn công an toàn thông tin
- 3. Một số giải pháp an toàn và bảo mật thông tin

1 – GIỚI THIỆU CHUNG

- Giới thiệu
- Thông tin
- Hệ thống và tài nguyên thông tin
- Các mối đe dọa đối với hệ thống và biện pháp ngăn chặn
- Các hiểm họa và quản lý rủi ro
- Các nguyên tắc và mục tiêu chung của ATBMTT
- An toàn bảo mật thông tin truyền trên mạng
- Các thành phần chính của ATBMTT

1 – GIỚI THIỆU CHUNG

- **Giới thiệu**
  - Trước đây (CNTT chưa phát triển mạnh), khi đề cập tới ATBMTT (Information Security), ta thường nghĩ đến các biện pháp nhằm đảm bảo cho thông tin được trao đổi, cất giữ an toàn và bí mật: Đóng dấu và ký niêm phong một bức thư, dùng mật mã mã hóa thông điệp, lưu trữ tài liệu mật trong két sắt có khóa,...
  - Khi CNTT phát triển mạnh (Internet), xuất hiện nhu cầu về an toàn và bảo mật thông tin trên máy tính. Có 2 mô hình an toàn bảo mật thông tin chính:
    - Bảo vệ thông tin trong quá trình truyền thông tin trên mạng (Network Security).
    - Bảo vệ hệ thống máy tính, và mạng máy tính, khỏi sự xâm nhập phá hoại từ bên ngoài (System Security).

1 – GIỚI THIỆU CHUNG

- **Thông tin**
  - Định nghĩa: Thông tin là những tính chất xác định của vật chất mà con người (hoặc hệ thống kỹ thuật) nhận được từ thế giới bên ngoài hoặc từ những quá trình xảy ra trong bản thân nó.
  - Thông tin tồn tại một cách khách quan, không phụ thuộc vào hệ thụ cảm.
- **Hệ thống và tài nguyên thông tin**
  - Khái niệm hệ thống: Hệ thống là một tập hợp các máy tính gồm thành phần phần cứng, phần mềm và dữ liệu làm việc được tích luỹ qua thời gian.
  - Tài nguyên thông tin: Phần cứng, phần mềm, dữ liệu, môi trường truyền thông giữa các máy tính, môi trường làm việc, con người.

1 – GIỚI THIỆU CHUNG

- **Các mối đe dọa đối với hệ thống và biện pháp ngăn chặn**
  - Các mối đe dọa:
    - Phá hoại: Phá hỏng thiết bị phần cứng, phần mềm trên hệ thống.
    - Sửa đổi: Tài sản của hệ thống bị sửa đổi trái phép.
    - Can thiệp: Tài sản bị truy cập bởi những người không có thẩm quyền. Các hành vi: Đánh cắp mật khẩu, ngăn chặn, mạo danh,…

    ⇒ Có 3 loại đối tượng chính khai thác:
      - Các đối tượng từ bên trong hệ thống (là những người có quyền truy cập hợp pháp)
      - Các đối tượng từ bên ngoài hệ thống (hacker, cracker,…)
      - Phần mềm (virus, spyware, mainware, các lỗ hổng phần mềm: SQL injection, …

1 – GIỚI THIỆU CHUNG

- **Các mối đe dọa đối với hệ thống và biện pháp ngăn chặn**
  - Các biện pháp ngăn chặn:
    - Thông qua phần mềm: Sử dụng các thuật toán mật mã học tại các cơ chế an toàn bảo mật của hệ thống mức hệ điều hành.
    - Thông qua phần cứng: Dùng các hệ mật mã đã được cứng hóa.
    - Thông qua các chính sách ATBMTT do tổ chức ban hành nhằm đảm bảo ATBMTT của hệ thống.

1 – GIỚI THIỆU CHUNG

- **Các hiểm họa và quản lý rủi ro**
  - Các hiểm họa:
    - Hiểm họa vô tình: khi NSD khởi động hệ thống ở chế độ đặc quyền (có thể tùy ý chỉnh sửa hệ thống) nhưng sau đó họ không chuyển sang chế độ thông thường, vô tình để kẻ xấu lợi dụng.
    - Hiểm họa cố ý: cố tình truy nhập hệ thống trái phép.
    - Hiểm họa thụ động: là hiểm họa nhưng chưa hoặc không tác động trực tiếp lên hệ thống (như nghe trộm trên đường truyền).
    - Hiểm họa chủ động: sửa đổi thông tin, thay đổi tình trạng hoặc hoạt động của hệ thống.

1 – GIỚI THIỆU CHUNG

- **Các hiểm họa và quản lý rủi ro**
  - Quản lý rủi ro:
    - Xác định rủi ro, sử dụng các giải pháp bảo vệ nhằm giảm thiểu rủi ro và xác định độ rủi ro có thể chấp nhận được trong hệ thống.
    - Đánh giá tổn thất có thể xảy ra trong quá trình sử dụng HTTT.
    - Phân tích các mối đe dọa tiềm năng và các điểm yếu có thể gây tổn thất cho HTTT.
    - Lựa chọn các giải pháp và các phương tiện tối ưu nhằm giảm thiểu rủi ro đến mức độ cho phép.

1 – GIỚI THIỆU CHUNG

- **Các nguyên tắc và mục tiêu chung của ATBMTT**
  - Các tính chất của hệ thống thông tin:
    - Nguồn thông tin là những tài sản rất có giá trị mang tính sống còn của một tổ chức.
    - Sự yếu kém và dễ bị tấn công của các hệ thống thông tin.
    - Nhiều vấn đề về an ninh cần phải quan tâm, từ đó có một lý do chính đáng để thay đổi phương thức bảo mật thông tin, mạng, máy tính.
  - Các nguyên tắc chung của ATBMTT:
    - Việc thẩm định về bảo mật phải đủ khó và cần tính tới tất cả các tình huống, khả năng tấn công có thể được thực hiện.
    - Tài sản phải được bảo vệ cho tới khi hết giá trị sử dụng hoặc hết bí mật.
  - Các mục tiêu chung của ATBMTT: Bí mật (Confidencial). Toàn vẹn (Integrity), tính xác thực (Authority), Sẵn sàng (Avaibility).

1 – GIỚI THIỆU CHUNG

- **Các thành phần chính của ATBMTT**
  - **An toàn mức vật lý:** Bảo vệ tài sản và thông tin, dễ thực hiện => Các biện pháp: làm sao để tổ chức càng ít trở thành mục tiêu tấn công càng tốt, phát hiện và ngăn chặn các kẻ đột nhập hay kẻ trộm, khôi phục những dữ liệu hay hệ thống quan trọng bị trộm hay mất mát.
  - **An toàn mức tác nghiệp:** Kiểm soát truy cập, chứng thực, an toàn topo mạng sau khi việc thiết lập mạng.
  - **An toàn mức quản lý và chính sách:** Cung cấp những hướng dẫn, những quy tắc, những quy trình để thiết lập một môi trường thông tin an toàn. Để phát huy hết hiệu quả thì phải có sự hỗ trợ triệt để từ phía các nhà quản lý.

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- Kẻ xâm nhập
- Các loại hình tấn công
- Phần mềm có hại
- Tấn công từ chối dịch vụ (DOS/DDOS)
- Tràn bộ đệm
- Một số phương pháp tấn công khác*

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Kẻ xâm nhập**
  - Khái niệm: Vấn đề quan trọng đối với hệ thống là chống lại việc truy cập không mong muốn mà kẻ xâm nhập có thể sử dụng các hệ thống làm hại để tấn công. Phân loại kẻ xâm nhập:
    - Kẻ giả danh
    - Kẻ lạm quyền
    - Người sử dụng giấu mặt
  - Các kỹ thuật xâm phạm:
    - Tìm mục tiêu và thu thập thông tin
    - Truy cập ban đầu
    - Leo thang quyền
    - Lần vết khôi phục
    - => Mục tiêu là giành được mật khẩu và sau đó dùng quyền truy cập của người sở hữu. Đoán mật khẩu là một trong những hướng tấn công chung nhất.

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Kẻ xâm nhập**
  - Phát hiện xâm nhập:
    - Cần phải: Chia khối để phát hiện nhanh, hành động ngăn chặn, thu thập thông tin để tăng cường an toàn.
    - Các cách tiếp cận phát hiện xâm nhập: Kiểm tra các bản ghi, phát hiện thống kê bất thường, phân tích kiểm tra bản ghi, phát hiện xâm nhập dựa trên qui tắc.
    - Quản trị mật khẩu: Tạo, quản lý mật khẩu,…
- **Phần mềm có hại**
  - Virus:
    - Khái niệm: Virus là đoạn mã lệnh (code) tự sinh lặp đính kèm với code khác như virus sinh học. Cả hai đều lan truyền tự nó và mang đi bộ tải: Mang theo code để tạo các bản sao của chính nó và thực hiện nhiệm vụ ngầm nào đó.
    - Thao tác của virus: Nằm im, lan truyền, kích hoạt, thực hiện bộ tải => Phụ thuộc vào máy tính và hệ điều hành để khai thác các tính chất và điểm yếu.

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Phần mềm có hại**
  - Virus:
    - Cấu trúc của virus

```
program V :=
    {goto main;
     1234567;
     subroutine infect-executable := {loop:
             file := get-random-executable-file;
             if (first-line-of-file = 1234567) then goto loop
             else prepend V to file; }
     subroutine do-damage := {whatever damage is to be done}
     subroutine trigger-pulled := {return true if condition holds}
     main: main-program := {infect-executable;
             if trigger-pulled then do-damage;
             goto next;}
     next:
}
```

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Phần mềm có hại**
  - Virus:
    - Phân loại virus: Virus ăn bám, virus cư trú ở bộ nhớ, Virus ở sector khởi động, lén lút, virus nhiều hình thái, virus biến hoá.
    - Một số loại virus:
      - Marco Virus: Marco code đính kèm file dữ liệu, được dịch bởi chương trình sử dụng file như marco của Word/Excel, sử dụng lệnh tự động & lệnh marco.
      - Virus email: Lan truyền sử dụng email được đính kèm chứa marco virus như Melissa.
      - Sâu: Là chương trình sinh lặp nhưng không có tác động, thường lan truyền trên mạng, có các loại sâu như: Sâu Morrris, sâu đương thời (Code Red, Nimda, SQL Slammer, Sobig, Mydoom,..).
    - Các biện pháp phòng chống Virus: Ngăn ngừa, phát hiện virus, nhiễm trong hệ thống, định danh loại virus nhiễm, loại bỏ khôi phục hệ thống về trạng thái sạch.

  => Sử dụng phần mềm chống virus và các kỹ thuật chống virus nâng cao (giải mã mẫu, sử dụng hệ thống miễn dịch số (IBM)).

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Phần mềm có hại**
  - Các kiểu phần mềm có hại khác Virus
    - Cửa sau hay cửa sập (trapdoor): Điểm vào chương trình bí mật, cho phép những người biết truy cập mà bỏ qua các thủ tục an toàn thông thường.
    - Bom logic: là phần mềm có hại kiểu cổ, code được nhúng trong chương trình hợp pháp, được kích hoạt khi gặp điều kiện xác định.
    - Ngựa thành Tơ roa: Chương trình với các tác động phụ được dấu kín (như trò chơi, phần mềm nâng cấp,…). Khi chạy thực hiện những nhiệm vụ bổ sung, cho phép kẻ tấn công gián tiếp dành quyền truy cập mà họ không thể trực tiếp. Thông thường sử dụng lan truyền virrus/sâu (worm) hoặc cài đặt cửa sau hoặc đơn giản phá hoại dữ liệu.
    - Zombie: là chương trình bí mật điều khiển máy tính của mạng khác và sử dụng để gián tiếp tiến hành các tấn công, thường sử dụng để khởi động tấn công từ chối các dịch vụ phân tán (DdoS) để khai thác các lỗ hổng trong các hệ thống.

HOẠT ĐỘNG LỚP HỌC

A: người ngoài, dùng danh tính của người khác.
B: người trong, có quyền thật nhưng dùng sai mục đích.
C: đã có quyền giám sát hoặc quản trị, và tìm cách xóa dấu vết hoặc né kiểm soát.

A Kẻ giả danh

B Kẻ lạm quyền

C Người dùng giấu mặt

A 1 Hacker mua được username và mật khẩu của một nhân viên trên chợ đen, rồi đăng nhập hệ thống công ty như chính người đó.

B 2 Quản trị viên hệ thống tò mò mở đọc email cá nhân của đồng nghiệp, dù việc đó không liên quan tới công việc được giao.

C 3 Kẻ tấn công sau khi chiếm được quyền admin đã tắt tính năng ghi nhật ký (log) để không ai lần ra hành vi của mình.

A 4 Một sinh viên dùng lại mật khẩu bị lộ trong vụ rò rỉ dữ liệu cũ để đăng nhập vào hộp thư của giảng viên.

B 5 Nhân viên bảo vệ có thẻ ra vào phòng máy chủ, tự ý cắm USB sao chép dữ liệu, dù nhiệm vụ chỉ là canh gác.

HOẠT ĐỘNG LỚP HỌC

- **Bom logic:** kích hoạt theo điều kiện.
- **Cửa sau:** lối vào bí mật, bỏ qua xác thực.
- **Trojan:** vỏ ngoài vô hại, bên trong có hại.
- **Zombie:** thiết bị bị điều khiển từ xa để tấn công hàng loạt.

Đây là loại mã độc nào?

B

① **Cửa sau (Trapdoor)**

A

② **Bom logic (Logic bomb)**

C

③ **Ngựa thành Tơ-roa (Trojan)**

D

④ **Zombie**

A Một lập trình viên bị sa thải đã để sẵn đoạn mã trong hệ thống: "nếu tên tôi biến mất khỏi bảng lương thì xoá toàn bộ cơ sở dữ liệu".

B Nhà phát triển phần mềm cài sẵn một mật khẩu bí mật, cho phép chính mình đăng nhập vào mọi hệ thống khách hàng mà bỏ qua thủ tục xác thực.

C Một ứng dụng "dọn dẹp máy tính miễn phí" tải về từ mạng, thực chất âm thầm cài thêm phần mềm gián điệp chạy ngầm.

D Hàng trăm nghìn camera an ninh bị chiếm quyền điều khiển từ xa, nằm im chờ lệnh để đồng loạt gửi yêu cầu tới một mục tiêu.

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Tấn công từ chối dịch vụ (DOS/DDOS)**
  - Khái niệm:
    - Tấn công từ chối dịch vụ từ xa (DDoS) tạo thành đe dọa lớn, làm cho hệ thống trở nên không sẵn sàng, làm tràn bởi sự vận chuyển vô ích.
    - Kẻ tấn công thường sử dụng một số lớn các "zombies", tăng độ khó của các tấn công
    - => Do đó, công nghệ bảo vệ tìm các biện pháp đương đầu chống lại.
  - Cách kẻ thù xây dựng mạng lưới tấn công từ chối dịch vụ từ xa:
    - Phần mềm cài đặt tấn công từ chối dịch vụ từ xa
    - Các lỗ hổng không vá được trong nhiều hệ thống
    - Chiến lược quét để tìm lỗ hổng hệ thống: sử dụng các yếu tố ngẫu nhiên, lập danh sách va chạm, tìm hiểu cấu trúc topo, mạng con cục bộ.

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Tấn công từ chối dịch vụ (DOS/DDOS)**
  - Khái niệm
  - Cách kẻ thù xây dựng mạng lưới tấn công từ chối dịch vụ từ xa
  - Chống tấn công từ chối dịch vụ từ xa (DDoS):
    - Ngăn ngừa tấn công và chiếm lĩnh trước.
    - Phát hiện tấn công và lọc trong quá trình sử dụng dịch vụ
    - Lần vết nguồn tấn công, xác định sự tấn công sau khi dùng xong dịch vụ.
    - Tóm lại: Phạm vi các khả năng tấn công rộng nên phải có nhiều biện pháp chống và sử dụng kết hợp.

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Tràn bộ đệm**
  - Khái niệm: Cơ chế tấn công phổ biến (bắt đầu từ 1988 xuất hiện sâu Morris, Code Red, Slammer, Sasser,…). Các kỹ thuật phòng chống đều đã biết nhưng vẫn còn là vấn đề cần quan tâm vì di truyền từ các con rệp đã lây lan rộng rãi, việc lập trình không cẩn thận.
  - Cơ sở của việc tràn bộ nhớ:
    - Sinh bởi do lỗi lập trình, cho quá nhiều dữ liệu lưu trữ hơn khả năng cho phép trong bộ đệm kích thước cố định.
    - Bộ đệm có thể trên ngăn xếp, đống, dữ liệu tổng thể.
    - Viết đè các vị trí nhớ cận kề làm hỏng dữ liệu của chương trình, truyền điều khiển không mong muốn, vi phạm truy cập bộ nhớ, thực hiện code của kẻ tấn công.

2 – MỘT SỐ DẠNG TẤN CÔNG AN TOÀN THÔNG TIN

- **Tràn bộ đệm**
  - Tấn công tràn bộ đệm:
    - Để làm tràn bộ đệm, kẻ tấn công cần phải phát hiện lỗ hổng tràn bộ đệm trong chương trình nào đó. Theo dõi, lần theo vết thực hiện, sử dụng các công cụ ẩn. Hiểu bộ đệm lưu trong bộ nhớ như thế nào và xác định khả năng phá hỏng.
    - Tràn bộ đệm ngăn xếp xảy ra khi bộ đệm đặt trên ngăn xếp, được khai thác bởi sâu Morris.
  - Code che đậy (Shell Code): là code chương trình được chuẩn bị bởi kẻ tấn công, nó được lưu trong bộ nhớ bị tràn và kẻ tấn công tìm cách chuyển điều khiển sang cho shell.
  - Bảo vệ tràn bộ nhớ: Bảo vệ trong thời gian dịch, bảo vệ trong thời gian chạy.

HOẠT ĐỘNG LỚP HỌC

1. **B. Ghi đè lên ô nhớ nằm ngay cạnh bộ đệm.** Ngôn ngữ như C không tự kiểm tra giới hạn, nên 32 byte thừa sẽ tràn sang và đè lên các ô nhớ kế tiếp. Đó chính là bản chất của tràn bộ đệm.
2. **B. Vì nó quyết định chương trình chạy tiếp ở đâu.** Nếu ghi đè được địa chỉ trả về, khi hàm kết thúc, chương trình sẽ nhảy tới đoạn mã mà kẻ tấn công chọn.
3. **B. DEP / NX bit và ASLR.** Đây là cơ chế của hệ điều hành và phần cứng, áp dụng lúc chạy nên không cần biên dịch lại. Ngược lại, stack canary và kiểm tra kiểu đều do trình biên dịch chèn vào, nên phải biên dịch lại mới có tác dụng.

Tràn bộ đệm

1 **Chương trình khai báo bộ đệm 8 byte rồi nhận vào một chuỗi 40 ký tự. Số dữ liệu thừa lưu ở đâu?**

A. Bị cắt bỏ, chỉ giữ 8 byte đầu **B.** Ghi đè lên ô nhớ nằm ngay cạnh bộ đệm **C.** Hệ điều hành tự cấp thêm bộ nhớ

2 **Vì sao kẻ tấn công đặc biệt nhắm vào ô nhớ chứa "địa chỉ trả về"?**

A. Vì nó chứa mật khẩu của chương trình **B.** Vì nó quyết định chương trình chạy tiếp ở đâu **C.** Vì đó là ô nhớ duy nhất không được bảo vệ

3 **Cơ chế nào vẫn có tác dụng mà KHÔNG cần biên dịch lại chương trình?**

A. Stack canary **B.** DEP / NX bit và ASLR **C.** Kiểm tra kiểu dữ liệu lúc biên dịch

3 – MỘT SỐ GIẢI PHÁP ATBMTT

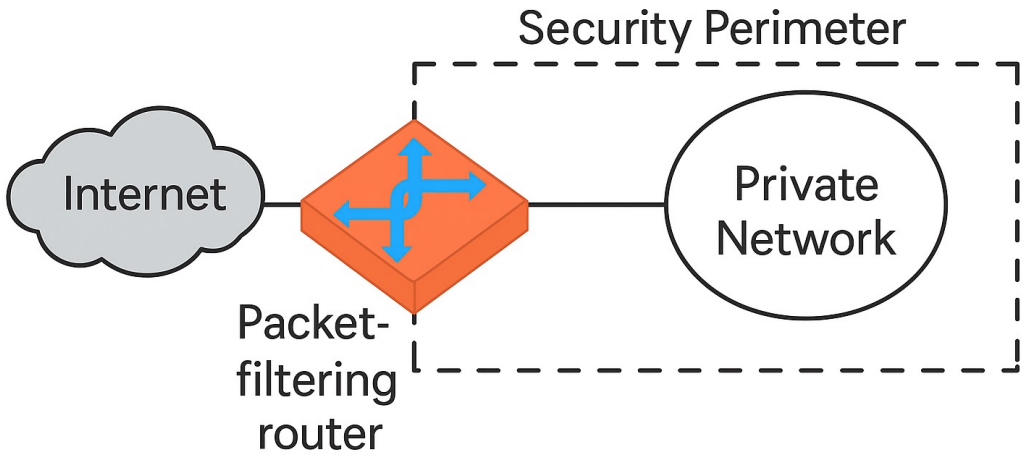
- Tường lửa (Firewall)
- Kiểm soát truy cập
- An toàn IP
- An toàn Web
- Thanh toán điện tử an toàn
- An toàn thư điện tử
- Một số giải pháp ATBMTT khác* (đọc nâng cao)

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **Tường lửa (Firewall)**
  - Khái niệm:
    - Là điểm "cổ chai" để kiểm soát và theo dõi an toàn trên mạng vì các mạng liên kết với độ tin cậy khác nhau nên buộc phải có hạn chế trên các dịch vụ của mạng,
    - Ví dụ: kiểm tra và kiểm soát truy cập, cài đặt cảnh báo, mạng riêng ảo (VPN) sử dụng cơ chế an toàn IPSec.
    - Hạn chế của tường lửa:
      - Không bảo vệ được các tấn công đi vòng qua nó (như: mạng lén lút, thiết bị modem,…),
      - Không bảo vệ chống các mối đe dọa từ bên trong (như: các nhân viên thông đồng với kẻ xấu,…),
      - không thể bảo vệ chống việc truyền các chương trình hoặc file nhiễm virus.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

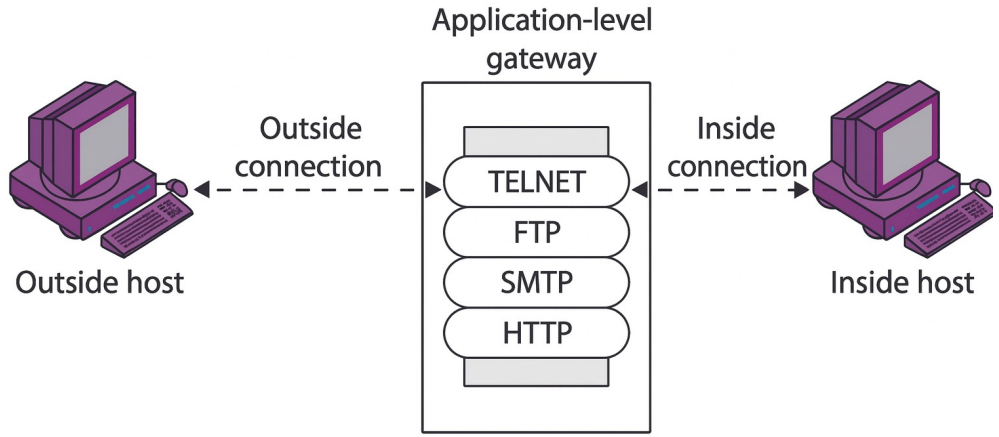
- **Tường lửa (Firewall)**
  - Bức tường lửa các lọc gói (packet-filtering router):
    - Là thành phần của tường lửa nhanh nhất và đơn giản nhất, là cơ sở của mọi hệ thống tường lửa.
    - Nó kiểm tra mỗi gói IP và cho phép/từ chối tuỳ theo qui tắc xác định, hạn chế truy cập đến các dịch vụ, các cổng.



(a) Packet-filtering router

3 – MỘT SỐ GIẢI PHÁP ATBMTT

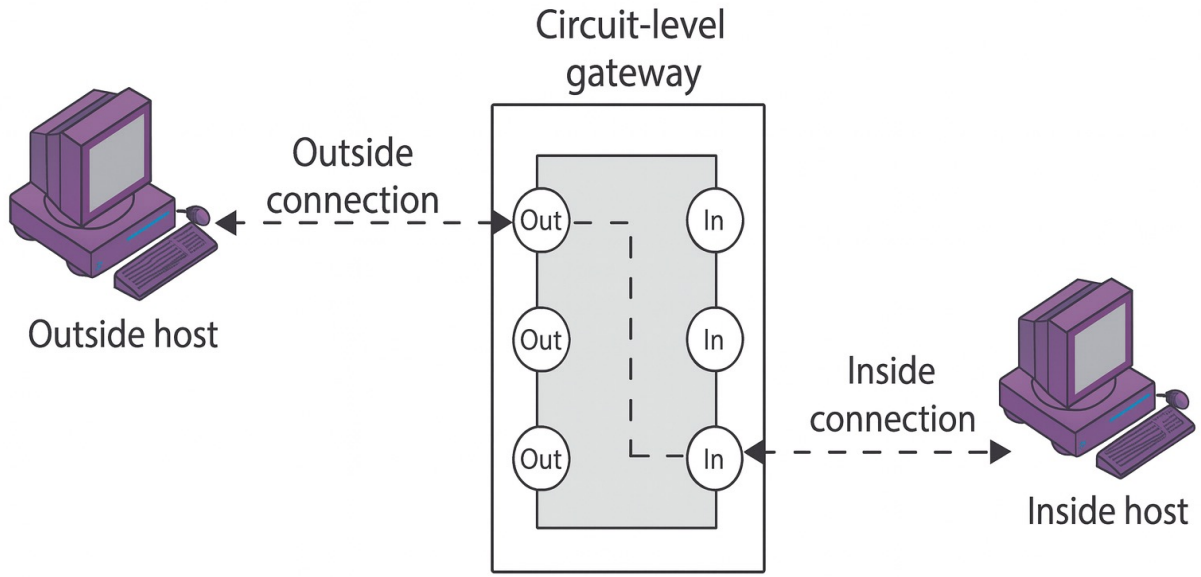
- **Tường lửa (Firewall)**
  - Bức tường lửa – cổng giao tiếp ở tầng ứng dụng (Application-level gateway hoặc proxy):
    - Có cổng giao tiếp chuyên dùng cho ứng dụng – proxy (người được uỷ quyền)
    - Có truy cập đầy đủ đến giao thức: Người sử dụng yêu cầu dịch vụ từ proxy, proxy kiểm tra các yêu cầu có hợp lệ không, sau đó xử lý yêu cầu và trả lời cho người sử dụng, có thể vào/theo dõi vận chuyển ở tầng ứng dụng
    - Cần các proxies khác nhau cho mỗi dịch vụ.



(b) Application-level gateway

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **Tường lửa (Firewall)**
  - Bức tường lửa – cổng giao tiếp mức mạch vòng (Circuitlevel gateway): Chuyển tiếp 2 kết nối TCP, có sự an toàn bằng cách hạn chế mà các kết nối này cho phép. Mỗi lần tạo ra chuyển tiếp thông thường không kiểm tra nội dung, được sử dụng khi tin cậy người sử dụng bên trong bằng cách cho phép các kết nối ra ngoài..



(c) Circuit-level gateway

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- Kiểm soát truy cập:
  - Khái niệm: Hệ thống đã xác định được định danh như người sử dụng, xác định các nguồn gốc nào nó có thể truy cập. Mô hình tổng quát là ma trận truy cập với: Chủ thể - thực thể chủ động (người sử dụng, quá trình), đối tượng thực thể bị động (file hoặc nguồn), quyền truy cập – cách mà đối tượng được truy cập; có thể được phân tách bởi: các cột (biểu diễn danh sách kiểm soát truy cập), các hàng (biểu diễn các thẻ về khả năng).
  - Ma trận kiểm soát quyền truy cập:

	Program1	**...**	**SegmentA**	**SegmentB**
Process1	Read Execute		Read Write	
Process2				Read
⋮				

(a) Access matrix

HOẠT ĐỘNG LỚP HỌC

Tường lửa và kiểm soát truy cập

1. **A. Packet-filtering router.** Loại này chỉ xét phần header (IP nguồn/đích, cổng, giao thức), không đọc nội dung bên trong gói tin.
2. **B. Application-level gateway.** Nó hoạt động ở tầng ứng dụng, nên mỗi dịch vụ cần một proxy hiểu riêng giao thức đó.
3. **A. Theo cột, tức Access Control List.** Quyền rwx được gắn vào từng file (đối tượng) và liệt kê ai được làm gì với file đó. Mỗi cột của ma trận ứng với một đối tượng, nên đây là cách cắt theo cột.
4. **C. Cả hai tình huống trên.** Tường lửa chỉ kiểm soát lưu lượng đi qua nó:
   - Phát wifi bằng 4G tạo một đường ra Internet vòng qua tường lửa.
   - Sao chép ra USB là mối đe dọa nội bộ, hoàn toàn không đi qua mạng.

1 **Loại tường lửa nào chỉ nhìn địa chỉ IP và cổng, không đọc nội dung gói tin?**

A. Packet-filtering router **B.** Application-level gateway **C.** Circuit-level gateway

2 **Loại nào cần một proxy riêng cho mỗi dịch vụ (HTTP, FTP, SMTP…)?**

A. Packet-filtering router **B.** Application-level gateway **C.** Circuit-level gateway

3 **Quyền rwx hiện ra khi chạy lệnh ls -l trong Linux là cách cắt ma trận truy cập theo chiều nào?**

A. Theo cột — Access Control List **B.** Theo hàng — Capability list **C.** Theo đường chéo của ma trận

4 **Tình huống nào tường lửa KHÔNG bảo vệ được?**

A. Nhân viên phát wifi từ điện thoại 4G **B.** Nhân viên nội bộ sao chép dữ liệu ra USB **C.** Cả hai tình huống trên

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn IP**
  - Khái niệm IPSec: IPSec là cơ chế an toàn IP tổng quan, nó cung cấp: xác thực, bảo mật và quản trị khoá. IPSec được dùng trên mạng LAN, WAN, mạng Internet.
  - Lợi ích của IPSec:
    - IPSec trên bức tường lửa/router cung cấp an toàn mạnh cho mọi việc truyền qua vành đai.
    - Nó chống lại việc đi vòng qua bức tường lửa/router.
    - IPSec nằm ở tầng vận chuyển bên dưới nên trong suốt với mọi ứng dụng và có thể trong suốt với người sử dụng đầu cuối nên có thể cung cấp an toàn cho NSD và bảo vệ kiến trúc rẽ nhánh.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn IP**
  - Kiến trúc an toàn IP: Có hai mở rộng an toàn cho phần đầu: Phần đầu xác thực (AH – Authentication Header) và tải trọng an toàn đóng gói (ESP – Encapsulating Security Payload).
    - Dịch vụ IPSec: IPSec nhằm đạt các mục đích: kiểm soát truy cập, toàn vẹn không kết nối, xác thực nguồn gốc dữ liệu, từ chối tải lại gói, bảo mật, bảo mật luồng vận chuyển có giới hạn.
    - Liên kết an toàn: Quan hệ một chiều giữa người gửi và người nhận mà cung cấp sự an toàn cho luồng vận chuyển và được xác định bởi 3 tham số: Chỉ số tham số an toàn, địa chỉ IP đích, tên thủ tục an toàn.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

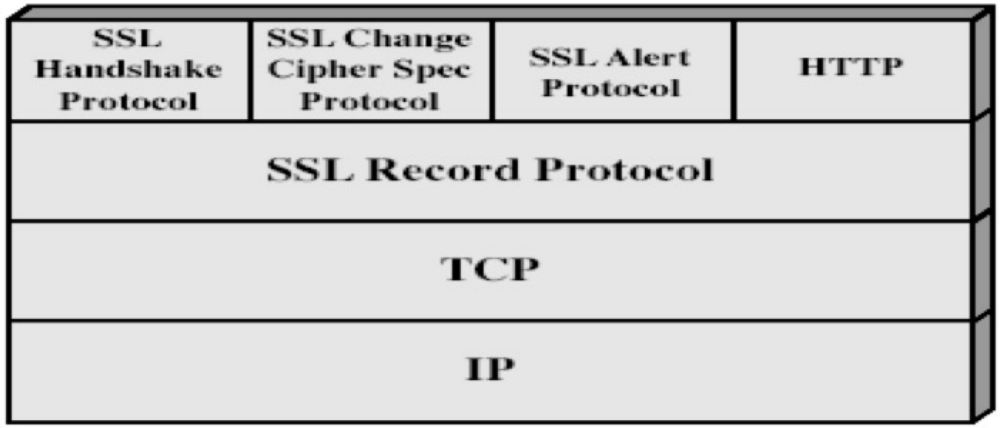
- **An toàn IP**
  - Kiến trúc an toàn IP:
    - Phần đầu xác thực (Authentication Header - AH): AH cung cấp sự hỗ trợ cho an toàn dữ liệu và xác thực của các gói IP: Hệ thống đầu cuối/chuyển mạch có thể xác thực người sử dụng/ứng dụng, ngăn tấn công theo dõi địa chỉ bằng việc theo dõi các chỉ số dãy. AH dựa trên sử dụng MAC: HMAC–MD5–96 hoặc HMAC – SHA -1-96 nên các bên cần chia sẻ khoá mật.
    - Tải trọng an toàn đóng gói (ESP): ESP đảm bảo bảo mật nội dung mẩu tin và luồng vận chuyển giới hạn, có lựa chọn cung cấp dịch vụ xác thực và hỗ trợ phạm vi rộng các mã, các chế độ mã, bộ đệm, baogồm: DES, Triple DES, RC5, CBC, và bộ đệm cần thiết để lấp đầy các kích thước khối, các trường cho luồng vận chuyển.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn IP**
  - Kiến trúc an toàn IP:
    - Chế độ vận chuyển và chế độ ống ESP: ESP được sử dụng với 2 chế độ: vận chuyển và ống. Chế độ ống không cần giữ tường minh địa chỉ đích.
      - Chế độ vận tải được dùng để mã và tuỳ chọn xác thực dữ liệu IP: Dữ liệu được bảo vệ nhưng phần đầu vẫn để rõ để biết địa chỉ đích, có thể phân tích vận chuyển một cách hiệu quả, tốt đối với ESP máy chủ vận chuyển tới máy chủ
      - Chế độ ống mã toàn bộ gói IP: Bổ sung phần đầu mới cho bước nhảy tiếp, tốt cho mạng riêng ảo VPN (Virtual Private Network), cổng đến cổng an toàn.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn Web**
  - Khái niệm an toàn Web: Web ngày càng được sử dụng rộng rãi nhưng Internet và Web có những lỗ hổng lớn và có nhiều mối đe doạ an toàn như: Tính toàn vẹn, bảo mật, từ chối dịch vụ, xác thực => Như vậy, cần bổ sung cơ chế bảo mật cho Web.
  - SSL (Secure Socket Layer):
    - SSL: SSL là dịch vụ an toàn tầng vận chuyển, ban đầu được phát triển bởi Netscape, nó được thiết kế cho đầu vào công cộng và trở thành chuẩn Internet, được biết đến như an toàn tầng vận chuyển TLS (Transport Layer Security). SSL sử dụng giao thức TCP để cung cấp dịch vụ đầu cuối đến cuối tin cậy và có 2 tầng thủ tục.
    - Kiến trúc SSL:

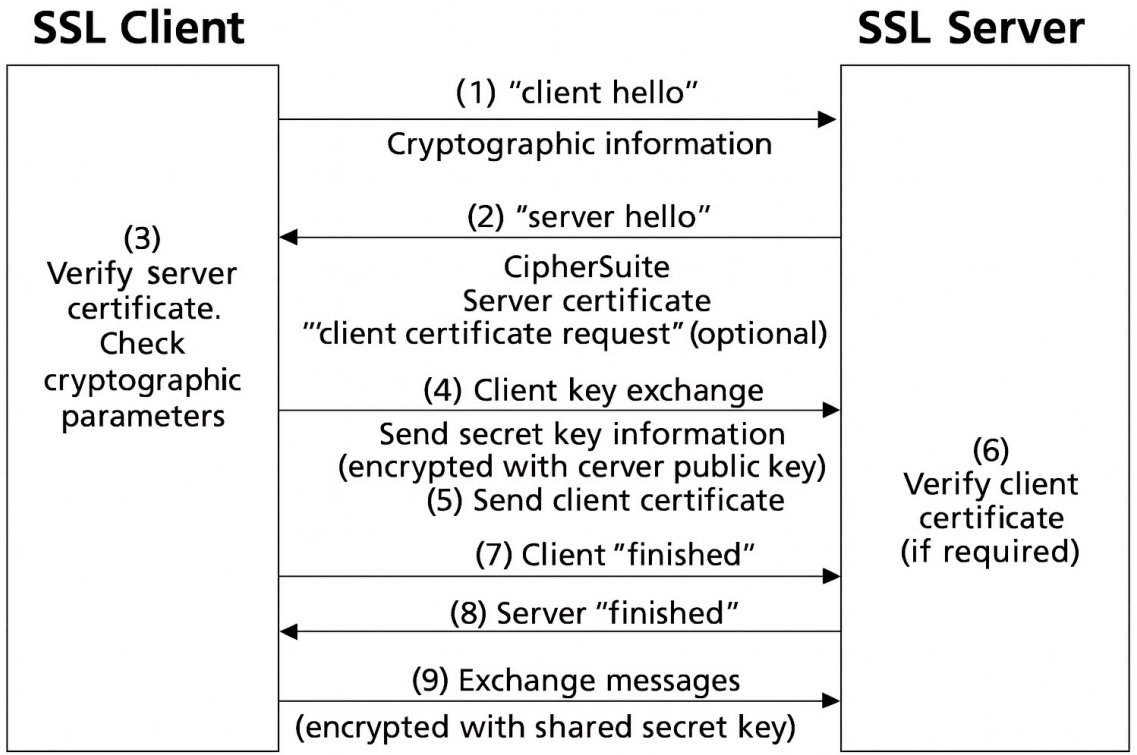


3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn Web**
  - SSL (Secure Socket Layer):
    - Kiến trúc SSL:
      - Dịch vụ thủ tục bản ghi SSL (SSL Record Protcol): Đảm bảo tính toàn vẹn của bản tin (sử dụng MAC với khoá mật chia sẻ, giống như HMAC nhưng với bộ đệm khác) và cung cấp bảo mật (sử dụng mã đối xứng với khoá chung xác định bởi thủ tục HandShake như: IDEA, RC2-40, DES-40, DES, 3DES, Fortezza, RC4-40, RC4-128 và bản tin được nén trước khi mã).
      - Thủ tục thay đổi đặc tả mã SSL (SSL Change Cipher Spec Protocol): Đây là một trong 3 giao thức chuyên biệt của SSL sử dụng thủ tục bản ghi SSL. Đây là mẩu tin đơn, buộc trạng thái treo trở thành hiện thời và cập nhật bộ mã đang dùng.
      - Thủ tục nhắc nhở SSL (SSL Alert Protocol): Truyền đi lời nhắc của SSL liên quan cho thành viên: Nghiêm khắc (nhắc nhở hoặc cảnh báo) và nhắc nhở đặc biệt. Nén và mã như mọi dữ liệu SSL.
      - An toàn tầng vận chuyển: IETF chuẩn RFC 2246 giống như SSLv3 nhưng có khác biệt nhỏ: số ký hiệu kích thước bản ghi, sử dụng HMAC thay cho MAC, hàm giả ngẫu nhiên tăng độ mật, có mã ghi chú bổ sung, có một số thay đổi hỗ trợ mã, thay đổi kiểu chứng nhận và thỏa thuận, thay đổi bộ đệm và tính toán mã.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

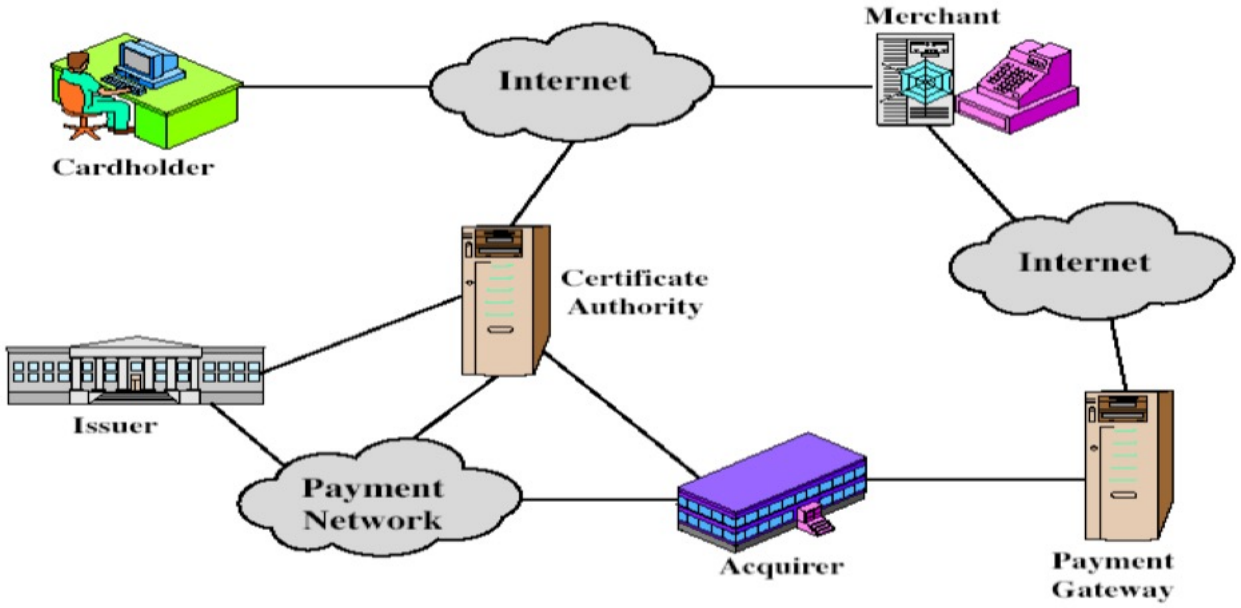
- **An toàn Web**
  - SSL (Secure Socket Layer):
    - Kiến trúc SSL:
      - Thủ tục bắt tay SSL (SSL HandShake Protocol): Thủ tục này cho phép máy chủ và máy trạm: Xác thực nhau, thỏa thuận thuật toán mã hoá và MAC, thỏa thuận khoá mã sẽ dùng.
      - Nó bao gồm một loạt các thông tin: Thiết lập các khả năng an toàn, xác thực máy chủ và trao đổi khoá, xác thực máy trạm và trao đổi khoá, kết thúc.



3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **Thanh toán điện tử an toàn**
  - Khái niệm: Đây là mã mở và đặc tả an toàn nhằm bảo vệ thanh toán thẻ tín dụng trên Internet (được phát triển bởi Master, Visa Card và không phải hệ thống trả tiền). Thanh toán điện tử an toàn là tập các giao thức và định dạng an toàn dùng để: Trao đổi an toàn giữa các đối tác, tin tưởng vì sử dụng X509v3, riêng biệt vì hạn chế thông tin cho người cần.

=> Các thành phần thanh toán điện tử:



3 – MỘT SỐ GIẢI PHÁP ATBMTT

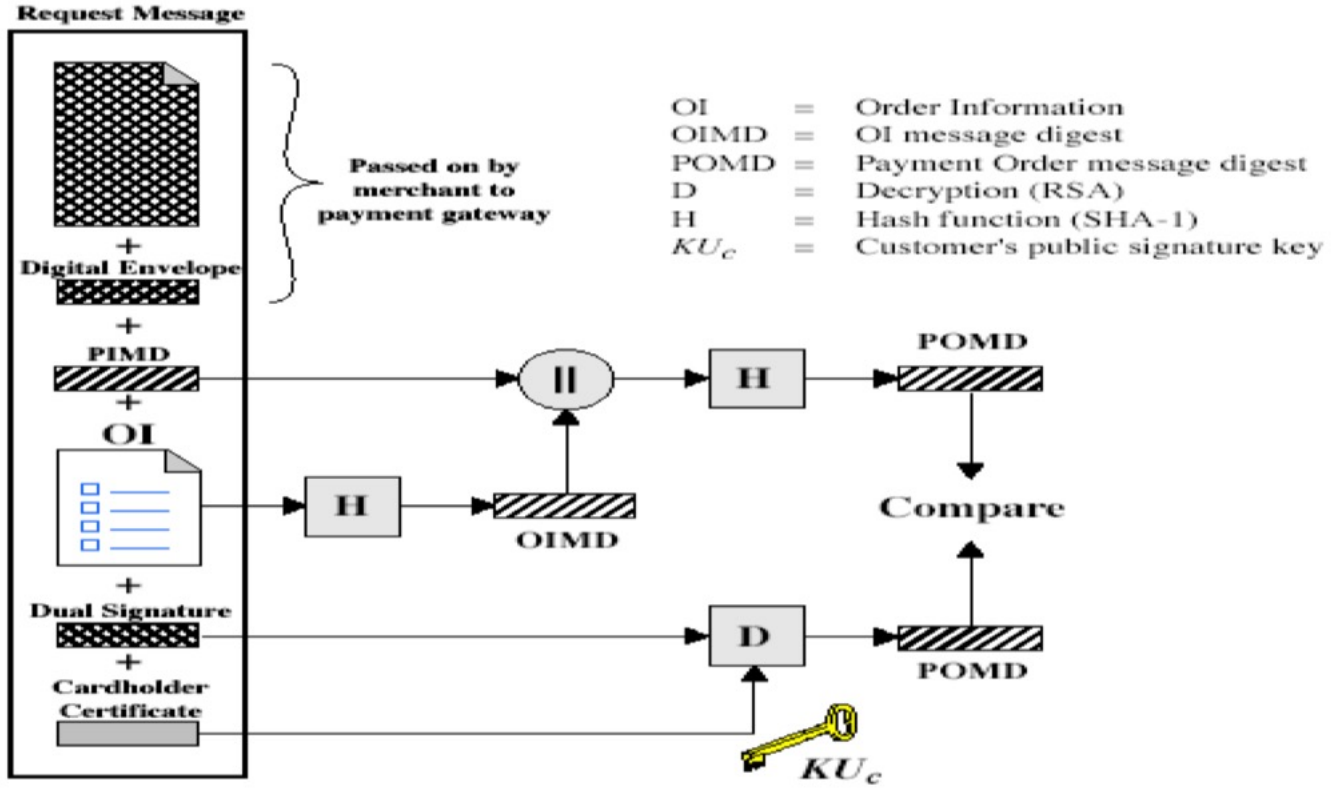
- **Thanh toán điện tử an toàn**
  - Thanh toán điện tử an toàn:
    - 1. Người mua mở tài khoản
    - 2. Người mua nhận được chứng nhận
    - 3. Người bán có chứng nhận của họ
    - 4. Người mua đặt hàng
    - 5. Người bán được kiểm chứng
    - 6. Đơn đặt hàng và trả tiền được gửi
    - 7. Người bán yêu cầu giấy phép trả tiền
    - 8. Người bán duyệt đơn đặt hàng
    - 9. Người bán cung cấp hàng và dịch vụ
    - 10. Người bán yêu cầu trả tiền

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **Thanh toán điện tử an toàn**
  - Chữ ký kép: Người mua tạo chữ ký kép: Thông tin đơn đặt OI cho người bán, thông tin trả tiền PI cho ngân hàng (không bên nào biết chi tiết của người khác nhưng họ phải được kết nối với nhau, ta sử dụng chữ ký kép cho mục đích này), ký trên bản ghép của OI và PI.
  - Trao đổi yêu cầu trả tiền gồm 4 mẩu tin:
    - Khởi tạo yêu cầu - nhận chứng nhận
    - Khởi tạo trả lời - ký trả lời
    - Yêu cầu trả tiền - của OI và PI
    - Trả lời trả tiền - đơn phúc đáp

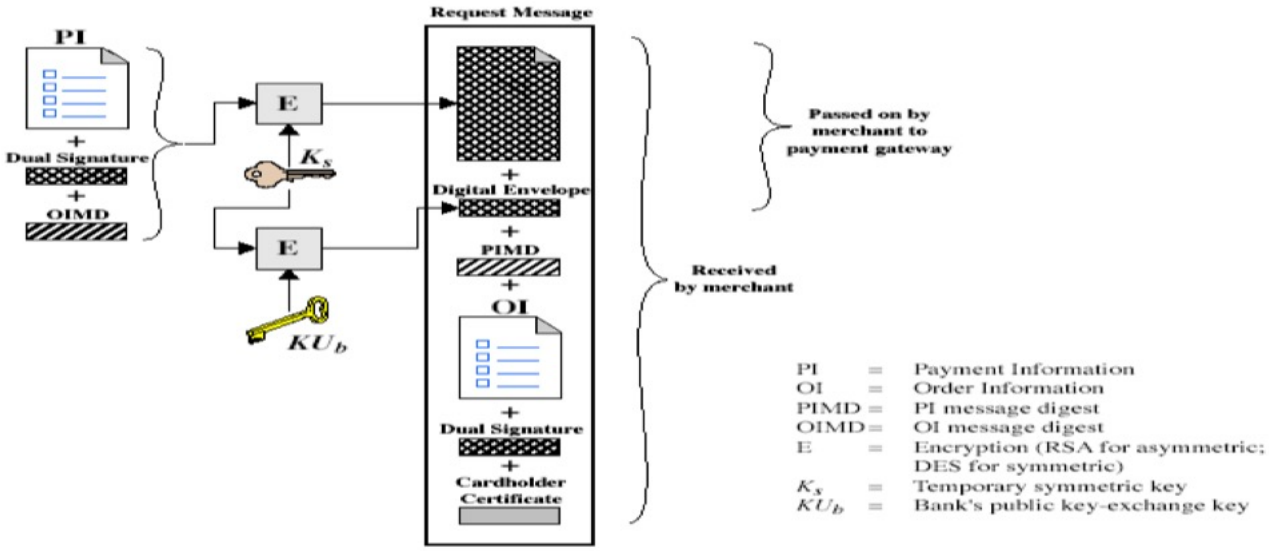
3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **Thanh toán điện tử an toàn**
  - Yêu cầu trả tiền – người mua



3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **Thanh toán điện tử an toàn**
  - Yêu cầu trả tiền – người bán:
    - Kiểm tra chứng nhận người giữ thẻ bằng chữ ký của CA.
    - Kiểm tra chữ ký kép bằng cách sử dụng khoá chữ ký công khai của người mua để tin tưởng rằng đơn không bị giả mạo khi truyền và được ký sử dụng chữ ký khoá riêng của người giữ thẻ.
    - Xử lý đơn đặt và gửi tiếp thông tin trả tiền cho cổng trả tiền để xác thực Gửi phản hồi trả tiền cho người giữ thẻ.



3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **Thanh toán điện tử an toàn**
  - Giấy phép cổng trả tiền
    - Kiểm chứng mọi chứng nhận. Giải mã phong bì điện tử của khối giấy phép và nhận được khoá đối xứng, sau đó giải mã khối giấy phép
    - Kiểm tra chữ ký của người bán trên khối giấy phép
    - Giải mã phong bì điện tử khối trả tiền, nhận được khoá đối xứng, sau đó giải mã khối trả tiền. Kiểm tra chữ ký kép trên khối trả tiền
    - Kiểm tra rằng, thanh toán ID nhận được từ người bán phù hợp với danh tính trong PI nhận được (không trực tiếp) từ người bánYêu cầu và nhận được giấy phép từ nơi phát hànhGửi trả lời giấy phép cho người bán
  - Nhận trả tiền:
    - Người bán gửi cho cổng trả tiền yêu cầu nhận trả tiền.Cổng kiểm tra yêu cầu đó. Sau đó yêu cầu chuyển tiền đến tài khoản người bán. Thông báo cho người bán và chờ trả lời việc nhận.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn thư điện tử**
  - Khái niệm: Thư điện tử là một trong những dịch vụ được coi trọng và ứng dụng rộng rãi. Nội dung của các bản tin sẽ có thể không an toàn, có thể bị quan sát trên đường truyền hoặc bởi những người có thẩm quyền thích hợp ở hệ thống đầu cuối. Do đó, phải đảm bảo các yêu cầu sau: tính bảo mật nội dung tin gửi, xác thực người gửi mẩu tin, tính toàn vẹn của mẩu tin, hơn nữa bảo vệ khỏi bị sửa, tính chống từ chối gốc, chống từ chối của người gửi.
  - Dịch vụ PGP:
    - Khái niệm: PGP (Pretty Good Privacy) là dịch vụ về bảo mật và xác thực được sử dụng rộng rãi cho chuẩn an toàn thư điện tử. PGP thường lựa chọn các thuật toán mã hoá tốt nhất để dùng, tích hợp thành một chương trình thống nhất, có thể chạy trên Unix, PC, Macintosh và các hệ thống khác.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn thư điện tử**
  - Hoạt động của PGP:
    - Thao tác PGP – xác thực PGP: Người gửi tạo mẩu tin, sử dụng thuật toán băm SHA-1 để sinh mẩu tin 160 bit, ký với RSA sử dụng khoá riêng của người gửi và đính kèm vào mẩu tin. Người nhận sử dụng RSA với khoá công khai của người gửi để giải mã và khôi phục bản băm. Người nhận kiểm tra mẩu tin nhận được sử dụng bản băm của nó và so sánh với bản băm đã được giải mã.
    - Thao tác PGP – bảo mật: Người gửi tạo mẩu tin và số ngẫu nhiên 128 bit như khoá phiên cho nó, mã hoá mẩu tin sử dụng CAST-128/IDEA /3DES với khoá phiên đó. Khoá phiên được mã sử dụng RSA với khoá công khai người nhận và đính kèm với mẩu tin. Người nhận sử dụng RSA với khoá riêng để giải mã và khôi phục khoá phiên. Khoá phiên được sử dụng để giải mã mẩu tin.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn thư điện tử**
  - Hoạt động của PGP:
    - Thao tác PGP - Bảo mật và xác thực: Có thể sử dụng cả hai dịch vụ trên cùng một mẩu tin. Tạo chữ ký và đính vào mẩu tin, sau đó mã cả mẩu tin và chữ ký. Đính khoá phiên đã được mã hoá RSA/ElGamal.
    - Thao tác PGP – nén: Mặc định PGP nén mẩu tin sau khi ký nhưng trước khi mã. Như vậy, cần lưu mẩu tin chưa nén và chữ ký để kiểm chứng về sau.
    - Thao tác PGP – tương thích thư điện tử: Khi sử dụng PGP sẽ có dữ liệu nhị phân để gửi (mẩu tin đã mã). Thư điện tử thiết kế chỉ cho văn bản. Vì vậy, PGP cần mã dữ liệu nhị phân thô vào các ký tự ASCII in được. Sau đó sử dụng thuật toán Radix 64 để ánh xạ 3 byte vào 4 ký tự in được và bổ sung kiểm tra thừa quay vòng CRC để phát hiện lỗi. PGP sẽ chia đoạn nhỏ mẩu tin nếu cần.

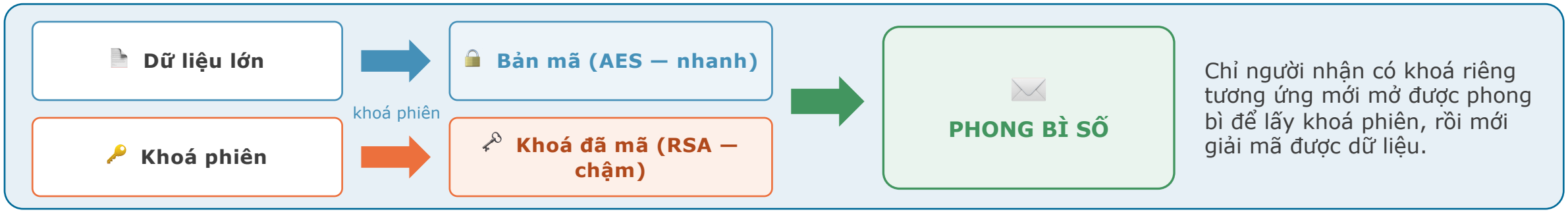
3 – MỘT SỐ GIẢI PHÁP ATBMTT

- **An toàn thư điện tử**
  - Mở rộng thư Internet đa mục đích/an toàn S/MIME:
    - Giới thiệu: Tăng cường an toàn cho thư điện tử đa mục đích mở rộng MIME (Multipurpose Internet Mail Extension). Thư điện tử Internet RFC822 gốc chỉ có văn bản, MIME cung cấp hỗ trợ cho nhiều kiểu nội dung và mẩu tin có nhiều phần với mã hoá dữ liệu nhị phân thành dạng văn bản. S/MIME tăng cường tính an toàn, có hỗ trợ của S/MIME trong nhiều tác nhân thư điện tử như: MS Outlook, Mozilla, Mac Mail,…
    - Các chức năng S/MIME: Dữ liệu đóng gói, nội dung được mã hoá và liên kết khoá, dữ liệu được ký, mẩu tin được mã và ký sau nén, mẩu tin gốc và mã hoá chữ ký trên bản nén, dữ liệu đóng gói và ký.
    - Các thuật toán mã hoá S/MIME: Các hệ chữ ký điện tử DSS và RSA, các hàm băm (hash): SHA-1 và MD5, mã khoá phiên: Sử dụng mã hóa Elgamal hoặc RSA, mã hóa mẩu tin: Sử dụng mã hóa AES, Triple-DES, RC2/40, …; MAC: HMAC với SHA-1.

3 – MỘT SỐ GIẢI PHÁP ATBMTT

"Phong bì số" — cơ chế chung của cả bốn giải pháp

IPSec, SSL/TLS, SET và PGP



Giải pháp	Mã đối xứng — dùng cho dữ liệu	Mã bất đối xứng — dùng cho khoá
IPSec (ESP)	AES	IKE / Diffie-Hellman
SSL / TLS	AES	RSA hoặc ECDHE
SET	DES (nay là AES)	RSA
PGP / S-MIME	CAST-128, IDEA, 3DES (nay là AES)	RSA, ElGamal

TÓM TẮT NỘI DUNG CHƯƠNG 1

- Trao đổi/thảo luận nhóm
- Bài tập/Thực hành
- Tóm tắt nội dung
- Câu hỏi và bài tập ôn tập

